

TokTickIT Sprint 3 Engineering Specification

1. Sprint Goal

Sprint 3 replaces the temporary Development Requester selector with real authentication and role-based authorization, and delivers the first operational IT Staff and Administrator experiences. By the end of the sprint, TokTickIT supports three authenticated roles: Requester, IT Staff, and Administrator, each seeing only the navigation and data their role permits, enforced by the server rather than by hiding UI controls. Requesters keep every Lab 2 ticket capability, now driven by their logged-in identity; IT Staff gain a shared Ticket Queue and Ticket Detail workflow for triage and resolution; Administrators gain a minimalist screen to create and manage user accounts.

2. Stakeholder Request (Interpreted)

The stakeholder needs the app to stop relying on a client-selectable "current Requester" and instead authenticate real users. Every user should log in with an email and password, and anyone given a temporary password must set their own password before doing anything else. Requesters should not notice a functional change beyond logging in; their tickets, attachments, and comments continue to work exactly as before, tied to who they actually are. IT Staff need a working queue so they can find tickets, take ownership, prioritize their own queue with an IT Priority, move a ticket through its lifecycle, and separate what the Requester sees (Public Comments) from what only the internal team sees (Internal Notes). Requesters may flag that their problem seems fixed, but only IT Staff or an Administrator can actually close the loop. Finally, Administrators need and only need a simple screen to onboard and maintain accounts: create a user, fix their basic details, assign their one role, turn them on or off, and reset a forgotten password to a new temporary one. Every one of these actions must be enforced on the backend, not just hidden in the UI.

3. Scope

3.1 Included

- Email + password authentication with hashed credentials, session cookie, logout, and a `GET /api/auth/me` endpoint for current-user retrieval.
- Mandatory password change on first login for any account created with an initial password.
- Server-side role-based authorization on every protected endpoint, with role-aware navigation in the client shell.
- Migration of ticket ownership from the Lab 2 Development Requester identity to real user records, with the temporary selector and its client-side state fully removed.
- Continued operation of all Lab 2 Requester Ticket and Attachment functionality, now scoped to the authenticated session instead of the `X-Dev-Requester-Id` header.
- IT Staff Ticket Queue: search, filter, sort, pagination, and an action to open Ticket Detail.
- IT Staff Ticket Detail: claim/assign/reassign ownership, set IT Priority, permitted status transitions, Public Comments, Internal Notes, and continued Attachment access.
- Requester Ticket Detail additions: Public Comments and a "Problem Appears Resolved" action.
- Minimalist Administrator User Management: list, search, optional role filter, create, edit basic fields, activate/deactivate, and set a new initial password.
- Zen Green visual and interaction consistency across all new and changed screens.

3.2 Explicitly Excluded

- Email invitations, password-reset email, multi-factor authentication, social login, SSO.
- Self-registration or Requester-created accounts.
- Actions Taken (deferred to Lab 4), formal SLA/escalation rules, notification services.
- Dashboards or KPI analytics beyond simple queue counts.
- Multi-tenant organizations, departments, or customer administration.
- Production-grade deployment or cloud infrastructure changes.
- Multiple roles per user; user deletion; bulk user operations; import/export; account-history screens; profile photos; account unlocking; administrator-approval workflows; mandatory pagination, multi-column sorting, or multiple simultaneous filters on the user list.

4. Functional Requirements

ID	Requirement
FR-01	The system authenticates a user by email and password and establishes a session on success.
FR-02	A user whose account requires a password change is blocked from all normal application screens until a new password is saved.
FR-03	The client can retrieve the current authenticated user's identity, role, and password-change flag via a dedicated endpoint.
FR-04	The client provides a Logout action that ends the session and blocks further authenticated access.
FR-05	The application shell shows only the navigation destinations and actions permitted for the current user's role.
FR-06	Every protected API endpoint independently re-checks authentication and role/ownership authorization, regardless of what the client UI shows.
FR-07	A Requester can create a Ticket, which is attributed to their authenticated identity.
FR-08	A Requester can view and manage only their own Tickets and related Attachments.
FR-09	A Requester can post Public Comments on their own Ticket.
FR-10	A Requester can mark that a problem appears resolved, without formally closing the Ticket.
FR-11	IT Staff can retrieve a shared Ticket Queue supporting search, filters, sorting, and pagination.
FR-12	IT Staff can open any Ticket's detail view regardless of who owns it.
FR-13	IT Staff or Administrator can claim an unassigned Ticket, or assign/reassign the Ticket Owner.

ID	Requirement
FR-14	IT Staff or Administrator can set or change a Ticket's IT Priority.
FR-15	IT Staff or Administrator can change a Ticket's status along the permitted transition matrix.
FR-16	IT Staff or Administrator can post Public Comments, visible to the Requester as well.
FR-17	IT Staff or Administrator can create Internal Notes, visible only to IT Staff and Administrators.
FR-18	An Administrator can view a searchable, role-filterable list of all users.
FR-19	An Administrator can create a user with a name, email, one role, activation state, and an initial password.
FR-20	An Administrator can edit a user's name, email, role, and activation state.
FR-21	An Administrator can set a new initial password for a user, forcing a password change at that user's next login.
FR-22	The system prevents an Administrator from deactivating their own account.
FR-23	The system prevents any action that would leave zero active Administrators.
FR-24	The system rejects duplicate email addresses on user creation and edit.
FR-25	All Lab 2 Ticket and Attachment functionality continues to work without the Development Requester selector.
FR-26	Every screen provides visible feedback for loading, validation, success, empty/no-results, forbidden, not-found, conflict, and unexpected-failure states where applicable.

5. Business Rules

ID	Rule
BR-01	Only an active user with valid credentials may authenticate.
BR-02	A user marked as requiring a password change cannot enter the normal application until a new valid password is saved.
BR-03	The authenticated user identity, not a <code>requesterId</code> supplied by the client, determines ownership of Requester operations.
BR-04	Public Comments are visible to the Requester, IT Staff, and Administrator. Internal Notes are visible only to IT Staff and Administrator.
BR-05	A Requester may indicate that the problem appears resolved, but cannot formally set the Ticket to Resolved or Closed.
BR-06	Lab 3 does not implement login-attempt lockout or rate limiting; each login attempt is validated independently against current credentials (account lockout is out of scope, consistent with the excluded MFA/advanced identity features).
BR-07	Passwords are hashed with <code>bcrypt</code> before storage; plaintext passwords are never persisted, logged, or returned by any API response.
BR-08	Any password set by an Administrator (at creation or via password reset) is treated as an initial password and forces <code>mustChangePassword = true</code> for that user.
BR-09	Logout clears the session cookie on the client and invalidates the session server-side; requests carrying the old session after logout are treated as unauthenticated.
BR-10	An inactive user cannot authenticate even with correct credentials. Login returns a distinct "account inactive" message but discloses no further account detail (see Assumption A-2).
BR-11	Email addresses are unique, case-insensitively, across all users. Duplicate email on create or edit is rejected with a conflict response.
BR-12	<code>GET /api/auth/me</code> returns 401 for an unauthenticated request; there is no default or anonymous identity.
BR-13	A Ticket's Requester is fixed at creation to the authenticated creator and is never changed by any later API call.

ID	Rule
BR-14	A Ticket Owner must be an active IT Staff or Administrator user. Assigning ownership to an inactive user or to a Requester is rejected.
BR-15	A Ticket may be unassigned (<code>ticketOwnerId = null</code>). Any active IT Staff or Administrator may claim an unassigned Ticket, which sets them as Owner.
BR-16	Ownership may be reassigned by the current Owner, any other IT Staff member, or an Administrator. A Requester cannot change ownership.
BR-17	Requested Priority is set once, by the Requester, at Ticket creation, and is never modified afterward by any role.
BR-18	IT Priority is initialized to equal Requested Priority at Ticket creation and may be changed only by IT Staff or Administrator thereafter.
BR-19	Ticket status changes must follow the transition matrix in §6.1; a request for a transition not listed there is rejected with 409 Conflict.
BR-20	Only IT Staff or Administrator may change Ticket status through the status-update endpoint; Requesters have no direct status-change capability.
BR-21	Consistent with BR-05, only IT Staff or Administrator may set status to Resolved or Closed.
BR-22	A Requester's "problem appears resolved" indicator can be set only on their own Ticket, and only while status is Open, In Progress, or Waiting for Requester.
BR-23	Public Comment and Internal Note content must be non-empty after trimming whitespace, and is capped at 2,000 characters; violations are rejected with 400.
BR-24	Public Comments and Internal Notes are append-only in Lab 3 no edit or delete endpoint is exposed.
BR-25	Every Comment/Note stores its author and creation time from the server session and clock; client-supplied author or timestamp values are ignored if present.
BR-26	A user has exactly one role at a time (Requester, IT Staff, or Administrator); Lab 3 has no multi-role assignment.
BR-27	An Administrator cannot deactivate their own account through the User Management screen.

ID	Rule
BR-28	The system must retain at least one active Administrator at all times; an edit that would deactivate or role-change the last active Administrator is rejected with 409.
BR-29	Deactivating a user does not delete or reassign their existing data (owned Tickets, Comments, Notes remain intact and attributed); Lab 3 has no user deletion.
BR-30	An inactive IT Staff/Administrator may remain the Owner of Tickets already assigned before deactivation (BR-14 blocks only <i>new</i> assignment); Lab 3 does not require automatic reassignment on deactivation.
BR-31	All Ticket and Attachment ownership checks that previously used the <code>X-Dev-Requester-Id</code> header now use the authenticated session identity exclusively; the header and the Development Requester selector are removed from client and server.

6. UI Specification Summary

Full detail, control-level layout, states, and responsive behavior are in `ui-spec.md`. Screen inventory:

Screen	Primary Role(s)	Modes
Login	Unauthenticated	View, submitting, error
Change Password (mandatory)	Any (when <code>mustChangePassword</code>)	View, submitting, error, success/continue
Application Shell (nav, profile, logout)	All authenticated	Role-conditional rendering
My Tickets / Create Ticket	Requester	List, create, view, edit (Lab 2 carryover)
Requester Ticket Detail	Requester	View, with Public Comments + "Problem Appears Resolved"
IT Staff Ticket Queue	IT Staff, Administrator*	List (search/filter/sort/paginate)
IT Staff Ticket Detail	IT Staff, Administrator*	View/edit of operational fields, Comments, Notes

Screen	Primary Role(s)	Modes
Administrator User Management	Administrator	List, create, edit

* Per §4.3 of the handout, an Administrator does not automatically get IT Staff ticket operations in Lab 3; see Assumption A-1.

6.1 Ticket Status Transition Matrix

Statuses: New, Open, In Progress, Waiting for Requester, Resolved, Closed, Reopened, Cancelled. All transitions below require IT Staff or Administrator (BR-20); a Requester never calls this endpoint.

From	Allowed To
New	Open, Cancelled
Open	In Progress, Waiting for Requester, Cancelled
In Progress	Waiting for Requester, Resolved, Cancelled
Waiting for Requester	In Progress, Resolved, Cancelled
Resolved	Closed, Reopened
Closed	Reopened
Reopened	Open, In Progress, Cancelled
Cancelled	(terminal)

Rules: a new Ticket starts at **New**. Claiming/assigning an Owner does not by itself change status. Any transition not listed is rejected (BR-19). No confirmation dialog is required for Lab 3 except Cancelled and Resolved, which the UI confirms before submitting (destructive/ finalizing actions).

7. Data Changes

Full field-level design is not duplicated here; see `api-spec.md` §3 for request/response shapes. Summary of model changes on top of the Lab 2 schema:

- **User** (*new*): `id` , `name` , `email` (unique, case-insensitive), `passwordHash` , `role` (enum: `REQUESTER` | `IT_STAFF` | `ADMINISTRATOR`), `isActive` (boolean, default `true`), `mustChangePassword` (boolean), `createdAt` , `updatedAt` .
- **Ticket** (*extended*): `requesterId` now a foreign key to `User` (was the Development Requester identifier); add `ticketOwnerId` (FK to `User` , nullable), `itPriority` (same enum as `requestedPriority`), `problemAppearsResolved` (boolean, default `false`), `resolutionSummary` (text, nullable, IT Staff/Admin-authored). Existing `requestedPriority` , `status` , `categoryId` , `relatedSystemId` , and timestamps are unchanged.
- **PublicComment** (*new*): `id` , `ticketId` (FK), `authorId` (FK to `User`), `content` , `createdAt` .
- **InternalNote** (*new*): `id` , `ticketId` (FK), `authorId` (FK to `User` , role IT Staff or Administrator at creation time), `content` , `createdAt` .
- **Category, RelatedSystem, Attachment**: unchanged in shape; Attachment ownership checks are revalidated against the authenticated session (BR-31) instead of the removed header.
- **Indexes**: unique index on `User.email` (case-insensitive), index on `Ticket.requesterId` , `Ticket.ticketOwnerId` , `Ticket.status` , and `PublicComment.ticketId` / `InternalNote.ticketId` for queue and detail queries.

7.1 Migration from Lab 2

1. Introduce the `User` table and seed it before touching `Ticket` .
2. For each distinct Development Requester identity found in existing Lab 2 `Ticket` rows, create a corresponding `User` with role `REQUESTER` , `isActive` = `true` , and a documented local-only initial password (`mustChangePassword` = `true`).
3. Backfill `Ticket.requesterId` to point at the new `User.id` for the matching identity; verify row counts match before and after (regression check, see `tests.md`).
4. Add `ticketOwnerId` , `itPriority` (backfilled to equal `requestedPriority` for all existing rows), and `problemAppearsResolved` (default `false`) to existing `Ticket` rows.
5. Remove the Development Requester selector component, its client-side state, and the `X-Dev-Requester-Id` header handling from both client and server once the migration is verified against the Lab 2 regression suite.
6. Migration must be idempotent-safe to re-run in a fresh local environment (drop/recreate + reseed), since it only runs against local development databases in this course.

8. API Contract (Summary)

Full endpoint list, request/response shapes, and status codes are in `api-spec.md` . Groupings:

- **Auth:** login, logout, current user, change password.
- **Requester Tickets (Lab 2 continuation):** create/list/get own tickets, attachments, public comments, "problem appears resolved."
- **IT Staff:** queue list, ticket detail, ownership, IT priority, status, public comments, internal notes.
- **Administrator:** user list, create user, edit user, set new initial password.

All endpoints require authentication except `POST /api/auth/login`. All responses follow the safe-error envelope defined in `api-spec.md §2.3`.

9. Acceptance Criteria

ID	Criterion
AC-01	Given an active user with valid credentials, when the user logs in, then the backend establishes authenticated access and returns the permitted user identity and role.
AC-02	Given a user who must change the initial password, when login succeeds, then normal application screens remain unavailable until a valid new password is saved.
AC-03	Given an authenticated Requester, when the client supplies another <code>requesterId</code> , then the backend still applies the authenticated identity and does not return another Requester's data.
AC-04	Given a Requester account, when an Internal Note endpoint is requested, then the operation is rejected without exposing note content.
AC-05	Given invalid credentials, when the user submits login, then the response is a generic "invalid email or password" message that does not reveal whether the email exists.
AC-06	Given a correct password for an inactive account, when the user submits login, then the response clearly indicates the account is inactive and no session is established.
AC-07	Given no active session, when the client calls <code>GET /api/auth/me</code> , then the response is 401 with no identity data.
AC-08	Given an authenticated user, when the user logs out, then a subsequent request with the old session cookie is treated as unauthenticated.
AC-09	Given an authenticated Requester, when they view navigation, then only Requester-permitted destinations are shown, and direct navigation to a Staff or Admin route is blocked server-side even if attempted.

ID	Criterion
AC-10	Given a Requester's own Ticket, when they create it, then <code>requesterId</code> equals their session identity regardless of any client-supplied value.
AC-11	Given a Ticket owned by another Requester, when the current Requester requests it directly by ID, then the response is 403/404 without exposing its content.
AC-12	Given a Requester on their own Ticket, when they post a Public Comment, then it is stored with their identity and server timestamp and is visible on the Ticket.
AC-13	Given a Requester's Ticket in Open/In Progress/Waiting for Requester, when they mark the problem as appearing resolved, then the flag is set and status is unchanged.
AC-14	Given a Requester's Ticket already Resolved or Closed, when they attempt to mark it appears-resolved, then the request is rejected.
AC-15	Given IT Staff, when they request the Ticket Queue with a search term, filters, sort, and page parameters, then only matching results for the current page are returned with correct pagination metadata.
AC-16	Given an unassigned Ticket, when IT Staff claims it, then they become the Ticket Owner.
AC-17	Given a Ticket owned by another active IT Staff member, when IT Staff or Administrator reassigns it to a third active IT Staff member, then ownership updates accordingly.
AC-18	Given an inactive user, when IT Staff attempts to assign them as Ticket Owner, then the request is rejected.
AC-19	Given IT Staff or Administrator, when they change IT Priority, then the new value is stored and Requested Priority is unchanged.
AC-20	Given a Ticket in status New, when IT Staff requests a transition to Resolved directly, then the request is rejected as an invalid transition.
AC-21	Given a Ticket in In Progress, when IT Staff sets status to Resolved, then the transition succeeds and is recorded.
AC-22	Given IT Staff or Administrator, when they post an Internal Note, then it is stored and is not returned to a Requester viewing the same Ticket.
AC-23	Given a Requester, when they attempt to call the Internal Note create endpoint directly, then the response is 403 and no note is created.

ID	Criterion
AC-24	Given an Administrator, when they request the user list with a search term and role filter, then only matching users are returned.
AC-25	Given valid new-user data, when an Administrator creates a user, then the user is created with <code>mustChangePassword = true</code> and can log in with the initial password.
AC-26	Given an email already in use, when an Administrator creates or edits a user with that email, then the request is rejected with a conflict response.
AC-27	Given an Administrator, when they attempt to deactivate their own account, then the request is rejected.
AC-28	Given exactly one active Administrator, when an edit would deactivate or role-change that account, then the request is rejected.
AC-29	Given an Administrator, when they set a new initial password for a user, then that user is forced through the mandatory password-change flow at next login.
AC-30	Given a non-Administrator, when they call any <code>/api/admin/*</code> endpoint, then the response is 403.
AC-31	Given the Lab 2 regression suite (ticket creation, attachments, categories, related systems), when run against the Lab 3 build under an authenticated Requester session, then all previously passing behavior still passes without the Development Requester header.
AC-32	Given any protected screen, when the underlying API call fails unexpectedly, then the UI shows safe failure feedback without leaking stack traces or internal error detail.

10. Definition of Done

A feature is complete only when **all** of the following hold on the final `main` branch:

1. The approved `specification.md`, `ui-spec.md`, `api-spec.md`, and `tests.md` for Lab 3 exist and predate the implementation PRs that satisfy them.
2. Every Functional Requirement (§4) and Business Rule (§5) is implemented and covered by at least one passing automated test referenced in `tests.md`.
3. Every Acceptance Criterion (§9) maps to at least one passing test, and that mapping is recorded in `tests.md`.

4. All protected API endpoints reject unauthenticated, unauthorized, and invalid requests with the safe-error shapes defined in `api-spec.md` verified by security/authorization tests, not just manual inspection.
5. The Lab 2 regression suite passes against the Lab 3 build using authenticated sessions instead of the Development Requester header.
6. Seed data satisfies §5.3 of the handout (idempotent, minimum account counts per role, realistic ticket distribution, non-sensitive example comments/notes) and is documented.
7. All required screens render correctly at desktop, tablet, and mobile widths with no clipping, overlap, or horizontal overflow, per the Zen Green visual checklist.
8. No plaintext password appears in source control, logs, or API responses.
9. `docs/lab-03/reviewer.md` shows PR links, reviewer identity, comments, responses, and approvals for every merged feature branch.
10. GitHub Issues for Sprint 3 are all in the Done column of the project board, and commit history shows feature branches merged into `lab3-staging` and then into `main`.

11. Assumptions and Decisions

ID	Assumption / Decision	Rationale
A-1	Administrator does not inherit IT Staff Ticket Queue/Detail permissions in Lab 3.	Handout §4.3 keeps the two responsibilities conceptually separate unless the matrix explicitly says otherwise; Lab 3 does not say otherwise.
A-2	Inactive-account login returns a distinct, clear "account is inactive" message (not a generic invalid-credentials message).	Handout UI requirement explicitly calls for "clear response for inactive accounts." This does confirm the email/password pair is valid, which is an accepted, documented trade-off scoped only to this one message.
A-3	Authentication uses a signed, <code>httpOnly</code> , <code>SameSite=Strict</code> session cookie (JWT-based) rather than a client-readable token.	Keeps the token out of client JS (XSS mitigation) while staying simple enough for a local-dev course stack; avoids a separate session store dependency.
A-4	Session lifetime is a fixed 8 hours; there is no refresh-token flow in Lab 3.	Matches a normal work session length; refresh flows are unnecessary

ID	Assumption / Decision	Rationale
		complexity given MFA/SSO are excluded.
A-5	Public Comments and Internal Notes share the same 2,000-character cap and append-only behavior.	Handout requires "justified length limits"; a single consistent limit is simplest to implement and test.
A-6	The Administrator "set a new initial password" action reuses the same underlying field/flag as user creation (<code>mustChangePassword</code>), rather than a separate password-reset entity.	Handout explicitly excludes password-reset email and advanced identity workflows; a direct field flip is the minimal mechanism that satisfies the requirement.
A-7	The Ticket Queue defaults to sorting by <code>createdAt</code> descending, page size 10, consistent with the reference queue screenshot.	No default was specified in the handout; matches the provided mockup.
A-8	"Reopened" is reachable from Resolved or Closed only, and from Reopened a ticket can move back into Open/In Progress/Cancelled (not directly back to Resolved/Closed) to force it through active work again.	Prevents skipping triage after a reopen; simplest matrix that satisfies "define a clear transition matrix."